

NIST SP 800-171 Rev 3 control 03.08.03 (03.08.03 Media Sanitization) is assessed by examining the following: Assessment Objectives: - system media that contain CUI are sanitized prior to disposal, release out of organizational control, or release for reuse.

NIST SP 800-53 Rev 5 control MP-8.1 (Documentation of Process) is assessed by examining, interviewing, and testing: MP-8.1 · Documentation of Process Control Statement: Document system media downgrading actions. Supplemental Guidance: Document system media downgrading actions. Organizations can document the media downgrading process by providing information, such as the downgrading technique employed, the identification number of the downgraded media, and the identity of the individual that authorized and/or performed the downgrading action.

NIST SP 800-171 Rev 3 control 03.08.02 (03.08.02 Media Access) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Media Protection (MP) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

MP-7.2 · Prohibit Use of Sanitization-resistant Media Control Statement: Prohibit the use of sanitization-resistant media in organizational systems. Supplemental Guidance: Prohibit the use of sanitization-resistant media in organizational systems. Sanitization resistance refers to how resistant media are to non-destructive sanitization techniques with respect to the capability to purge information from media. Certain types of media do not support sanitization commands, or if supported, the interfaces are not supported in a standardized way across these devices. Sanitization-resistant media includes compact flash, embedded flash on boards and devices, solid state drives, and USB removable media.

Under the FedRAMP High baseline, MP-4 (MP-4 Media Storage): FedRAMP High Baseline · MP-4 · Media Storage Control Statement: a. Physically control and securely store [organization-defined parameter] within [organization-defined parameter] ; and b. Protect system media types defined in MP-4a until the media are destroyed or sanitized using approved equipment, techniques, and procedures. Supplemental Guidance: a. Physically control and securely store [organization-defined parameter] within [organization-defined parameter] ; and b. Protect system media typ

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Media Protection 3.8.7 System Media Restrictions a. Restrict or prohibit the use of [Assignment: organization-defined types of system media] (03.08.07.a). b. Prohibit the use of removable system media without an identifiable owner. Related Controls: MP-07 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.08.07.a [Assignment: organization-defined types of system media] any removable media not managed by or on behalf of the organization Personnel Security 3.9.1 Screening and Rescreening a. Screen individuals prior to authorizing access to the system. b. Rescreen individuals in accordance with [Assignment: organization-defined conditions requiring rescreening] (03.09.01.b). Related Controls: PS-03 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.09.01.

NIST SP 800-171 Rev 3 control 03.08.03 (03.08.03 Media Sanitization) falls under the Media Protection family. 03.08.03 · Media Sanitization Supplemental Guidance: Media sanitization applies to digital and non-digital media that are subject to disposal or reuse, whether or not the media are considered removable. Examples include digital media in scanners, copiers, printers, notebook computers, mobile devices, workstations, network components, and non-digital media. The sanitization process removes CUI from media such that the information cannot be retrieved or reconstructed. Sanitization techniques (e.g Supplemental Guidance: Media sanitization applies to digital and non-digital media that are subject to disposal or reuse, whether or not the media are considered removable. Examples include digital media in scanners, copiers, printers, notebook computers, mobile devices, workstations, network components, and non-digital media. The sanitization process removes CUI from media such that the information cannot be retrieved or reconstructed. Sanitization techniques (e.g., cryptographically erasing, c

19: The device can prevent unauthorized access to all sensitive data on its storage devices. | Expectation 19: The device can prevent unauthorized access to all sensitive data on its storage devices. | Expectation 19: The device can prevent unauthorized access to all sensitive data on its storage devices. | | 31. The IoT device may not provide sufficiently strong encryption capabilities

for its stored data. Risk Consideration 3 | · MP-4, Media Storage · SC-28, Protection of Information at Rest | · Increases the likelihood of unauthorized access to or tampering with sensitive data. | · PR.DS-1: Data-at-rest is protected · PR.PT-2: Removable media is protected and its use restricted according to policy | | 32. The IoT device may not provide a mechanism for sanitizing sensitive data before disposing of or repurposing the device. Risk Consideration 3 | · MP-6, Media Sanitization | · Increases the likelihood of unauthorized access to sensitive data. | · PR.IP-6: Data is destroyed according to policy | | Expectation 20: The device has a mechanism to support data availability through secure backups. | Expectation 20: The device has a mechanism to support data availability through secure backups. | Expectation 20: The device has a mechanism to support data availability through secure backups. | Expectation 20: The device has a mechanism to support data availability through secure backups. | | 33. The IoT device may not provide a secure backup and restore mechanism for its data.

NIST SP 800-53 Rev 5 control MP-6.1 (Review, Approve, Track, Document, and Verify) is assessed by examining, interviewing, and testing: MP-6.1 · Review, Approve, Track, Document, and Verify Control Statement: Review, approve, track, document, and verify media sanitization and disposal actions. Supplemental Guidance: Review, approve, track, document, and verify media sanitization and disposal actions. Organizations review and approve media to be sanitized to ensure compliance with records retention policies. Tracking and documenting actions include listing personnel who reviewed and approved sanitization and disposal actions, t

Under the FedRAMP Moderate baseline, MP-6 (MP-6 Media Sanitization): FedRAMP Moderate Baseline · MP-6 · Media Sanitization Control Statement: a. Sanitize [organization-defined parameter] prior to disposal, release out of organizational control, or release for reuse using [organization-defined parameter] ; and b. Employ sanitization mechanisms with the strength and integrity commensurate with the security category or classification of the information. Supplemental Guidance: a. Sanitize [organization-defined parameter] prior to disposal, release out of organizati

MP-8.2 · Equipment Testing Control Statement: Test downgrading equipment and procedures [organization-defined parameter] to ensure that downgrading actions are being achieved. Supplemental Guidance: Test downgrading equipment and procedures [organization-defined parameter] to ensure that downgrading actions are being achieved. None.

MP-6.3 · Nondestructive Techniques Control Statement: Apply nondestructive sanitization techniques to portable storage devices prior to connecting such devices to the system under the following circumstances: [organization-defined parameter]. Supplemental Guidance: Apply nondestructive sanitization techniques to portable storage devices prior to connecting such devices to the system under the following circumstances: [organization-defined parameter]. Portable storage devices include external or removable hard disk drives (e.g., solid state, magnetic), optical discs, magnetic or optical tapes, flash memory devices, flash memory cards, and other external or removable disks. Portable storage devices can be obtained from untrustworthy sources and contain malicious code that can be inserted into or transferred to organizational systems through USB ports or other entry portals. While scanning storage devices is recommended, sanitization provides additional assurance that such devices are free of malicious code. Organizations consider nondestructive sanitization of portable storage devices when the devices are purchased from manufacturers or vendors prior to initial use or when organizations cannot maintain a positive chain of custody for the devices.

NIST SP 800-171 Rev 3 control 03.08.05 (03.08.05 Media Transport) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Media Protection (MP) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control MP-3 (Media Marking) is assessed by examining, interviewing, and testing: MP-3 · Media Marking Control Statement: a. Mark system media indicating the distribution limitations, handling caveats, and applicable security markings (if any) of the information; and b. Exempt [organization-defined parameter] from marking if the media remain within [organization-defined parameter]. Supplemental Guidance: a. Mark system media indicating the distribution limitations, handling caveats, and applicable security markings (if any) of the information; and b.

Exempt [organization-de

NIST SP 800-53 Rev 5 control MP-6.2 (Equipment Testing) summarizes the requirements for this control: MP-6.2 · Equipment Testing Control Statement: Test sanitization equipment and procedures [organization-defined parameter] to ensure that the intended sanitization is being achieved. Supplemental Guidance: Test sanitization equipment and procedures [organization-defined parameter] to ensure that the intended sanitization is being achieved. Testing of sanitization equipment and procedures may be conducted by qualified and authorized external entities, including federal agencies or external servi

NIST SP 800-171 Rev 3 control 03.08.05 (03.08.05 Media Transport) requires organizations to implement the following: Control Statement: SR-03.08.05.a Protect and control system media that contain CUI during transport outside of controlled areas. SR-03.08.05.b Maintain accountability of system media that contain CUI during transport outside of controlled areas. SR-03.08.05.c Document activities associated with the transport of system media that contain CUI. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.08.05.

NIST SP 800-171 Rev 3 control 03.08.01 (03.08.01 Media Storage) is assessed by examining the following: Assessment Objectives: - system media that contain CUI are physically controlled. - system media that contain CUI are securely stored.

MP-6.1 · Review, Approve, Track, Document, and Verify Control Statement: Review, approve, track, document, and verify media sanitization and disposal actions. Supplemental Guidance: Review, approve, track, document, and verify media sanitization and disposal actions. Organizations review and approve media to be sanitized to ensure compliance with records retention policies. Tracking and documenting actions include listing personnel who reviewed and approved sanitization and disposal actions, types of media sanitized, files stored on the media, sanitization methods used, date and time of the sanitization actions, personnel who performed the sanitization, verification actions taken and personnel who performed the verification, and the disposal actions taken. Organizations verify that the sanitization of the media was effective prior to disposal.

NIST SP 800-171 Rev 3 control 03.08.09 (03.08.09 System Backup · Cryptographic Protection) is assessed by examining the following: Assessment Objectives: - cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI at backup storage locations. - the confidentiality of backup information is protected.

NIST SP 800-171 Rev 3 control 03.08.02 (03.08.02 Media Access) requires organizations to implement the following: 03.08.02 · Media Access Supplemental Guidance: System media include digital and non-digital media. Access to CUI on system media can be restricted by physically controlling such media. This includes conducting inventories, ensuring that procedures are in place to allow individuals to check out and return media to the media library, and maintaining accountability for stored media. For digital media, access to CUI can be restricted by using cryptographic means. Encrypting data in storage or at re For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.08.02.

NIST SP 800-171 Rev 3 control 03.08.03 (03.08.03 Media Sanitization) is assessed by examining the following: Assessment Objectives: - system media that contain CUI are sanitized prior to disposal, release out of organizational control, or release for reuse.

NIST SP 800-53 Rev 5 control MP-8.3 (Controlled Unclassified Information) is assessed by examining, interviewing, and testing: MP-8.3 · Controlled Unclassified Information Control Statement: Downgrade system media containing controlled unclassified information prior to public release. Supplemental Guidance: Downgrade system media containing controlled unclassified information prior to public release. The downgrading of controlled unclassified information uses approved sanitization tools, techniques, and procedures.

NIST SP 800-171 Rev 3 control 03.08.07 (03.08.07 Media Use) is assessed by examining the following: Assessment Objectives: - the use of the following types of system media is restricted or prohibited:

[organization-defined parameter]. - the use of removable system media without an identifiable owner is prohibited.

NIST SP 800-53 Rev 5 control MP-2 (Media Access) is assessed by examining, interviewing, and testing: MP-2 · Media Access Control Statement: Restrict access to [organization-defined parameter] to [organization-defined parameter]. Supplemental Guidance: Restrict access to [organization-defined parameter] to [organization-defined parameter]. System media includes digital and non-digital media. Digital media includes flash drives, diskettes, magnetic tapes, external or removable hard disk drives (e.g., solid state, magnetic), compact discs, and digital versatile discs. Non-digital media includes

and b. Prohibit the use of portable storage devices in organizational systems when such devices have no identifiable owner. Discussion: System media includes both digital and non-digital media. Digital media includes diskettes, magnetic tapes, flash drives, compact discs, digital versatile discs, and removable hard disk drives. Non-digital media includes paper and microfilm. Media use protections also apply to mobile devices with information storage capabilities. In contrast to MP-2, which restricts user access to media, MP-7 restricts the use of certain types of media on systems, for example, restricting or prohibiting the use of flash drives or external hard disk drives. Organizations use technical and nontechnical controls to restrict the use of system media. Organizations may restrict the use of portable storage devices, for example, by using physical cages on workstations to prohibit access to certain external ports or disabling or removing the ability to insert, read, or CHAPTER THREE PAGE 176 NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

write to such devices. Organizations may also limit the use of portable storage devices to only approved devices, including devices provided by the organization, devices provided by other approved organizations, and devices that are not personally owned.

Control MP-5: or transport, ensuring that media enters the appropriate transport processes, and the actual transport. Authorized transport and courier personnel may include individuals external to the organization. Maintaining accountability of media during transport includes restricting transport activities to authorized personnel and tracking and/or obtaining records of transport activities as the media moves through the transportation system to prevent and detect loss, destruction, or tampering. Organizations establish documentation requirements for activities associated with the transport of system media in accordance with organizational assessments of risk. Organizations maintain the flexibility to define record-keeping methods for the different types of media transport as part of a system of transport-related records. Related Controls: AC-7, AC-19, CP-2, CP-9, MP-3, MP-4, PE-16, PL-2, SC-12, SC-13, SC-28, SC-34. Control Enhancements: (1) MEDIA TRANSPORT | PROTECTION OUTSIDE OF CONTROLLED AREAS [Withdrawn: Incorporated into MP-5.] (2) MEDIA TRANSPORT | DOCUMENTATION OF ACTIVITIES [Withdrawn: Incorporated into MP-5.] (3) MEDIA TRANSPORT | CUSTODIANS Employ an identified custodian during transport of system media outside of controlled areas. Discussion: Identified custodians provide organizations with specific points of contact during the media transport process and facilitate individual accountability. Custodial responsibilities can be transferred from one individual to another if an unambiguous custodian is identified. Related Controls: None. (4) MEDIA TRANSPORT | CRYPTOGRAPHIC PROTECTION [Withdrawn: Incorporated into SC-28(1).] References: [FIPS 199], [SP 800-60-1], [SP 800-60-2].

NIST SP 800-171 Rev 3 control 03.08.07 (03.08.07 Media Use) requires organizations to implement the following: Control Statement: SR-03.08.07.a Restrict or prohibit the use of [organization-defined parameter]. SR-03.08.07.b Prohibit the use of removable system media without an identifiable owner. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.08.07.

MP-8.4 · Classified Information Control Statement: Downgrade system media containing classified information prior to release to individuals without required access authorizations. Supplemental Guidance: Downgrade system media containing classified information prior to release to individuals without required access authorizations. Downgrading of classified information uses approved sanitization tools, techniques, and procedures to transfer information confirmed to be unclassified from classified systems to unclassified media.

NIST SP 800-171 Rev 3 control 03.08.02 (03.08.02 Media Access) falls under the Media Protection family. 03.08.02 · Media Access Supplemental Guidance: System media include digital and non-digital media. Access to CUI on system media can be restricted by physically controlling such media. This includes conducting inventories, ensuring that procedures are in place to allow individuals to check out and return media to the media library, and maintaining accountability for stored media. For digital media, access to CUI can be restricted by using cryptographic means. Encrypting data in storage or at rest Supplemental Guidance: System media include digital and non-digital media. Access to CUI on system media can be restricted by physically controlling such media. This includes conducting inventories, ensuring that procedures are in place to allow individuals to check out and return media to the media library, and maintaining accountability for stored media. For digital media, access to CUI can be restricted by using cryptographic means. Encrypting data in storage or at rest is addressed in [(#)/c

NIST SP 800-171 Rev 3 control 03.08.05 (03.08.05 Media Transport) requires organizations to implement the following: Control Statement: SR-03.08.05.a Protect and control system media that contain CUI during transport outside of controlled areas. SR-03.08.05.b Maintain accountability of system media that contain CUI during transport outside of controlled areas. SR-03.08.05.c Document activities associated with the transport of system media that contain CUI. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.08.05.

NIST SP 800-53 Rev 5 control MP-6.3 (Nondestructive Techniques) is assessed by examining, interviewing, and testing: MP-6.3 · Nondestructive Techniques Control Statement: Apply nondestructive sanitization techniques to portable storage devices prior to connecting such devices to the system under the following circumstances: [organization-defined parameter]. Supplemental Guidance: Apply nondestructive sanitization techniques to portable storage devices prior to connecting such devices to the system under the following circumstances: [organization-defined parameter]. Portable storage devices include external o

NIST SP 800-53 Rev 5 control MP-7.2 (Prohibit Use of Sanitization-resistant Media) summarizes the requirements for this control: MP-7.2 · Prohibit Use of Sanitization-resistant Media Control Statement: Prohibit the use of sanitization-resistant media in organizational systems. Supplemental Guidance: Prohibit the use of sanitization-resistant media in organizational systems. Sanitization resistance refers to how resistant media are to non-destructive sanitization techniques with respect to the capability to purge information from media. Certain types of media do not support sanitization commands, or if supported, the int

NIST SP 800-53 Rev 5 control MP-1 (Policy and Procedures) summarizes the requirements for this control: MP-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] media protection policy that: 2. Procedures to facilitate the implementation of the media protection policy and the associated media protection controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the media protection policy and procedures; and c. Review and update t

NIST SP 800-171 Rev 3 control 03.08.09 (03.08.09 System Backup · Cryptographic Protection) requires organizations to implement the following: Control Statement: SR-03.08.09.a Protect the confidentiality of backup information. SR-03.08.09.b Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI at backup storage locations. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.08.09.

NIST SP 800-53 Rev 5 control MP-4 (Media Storage) is defined as follows: MP-4 · Media Storage Control Statement: a. Physically control and securely store [organization-defined parameter] within [organization-defined parameter] ; and b. Protect system media types defined in MP-4a until the media are destroyed or sanitized using approved equipment, techniques, and procedures. Supplemental Guidance: a. Physically control and securely store [organization-defined parameter] within [organization-defined parameter] ; and b. Protect system media types defined in MP-4a until the media are destroyed or sanitized using approved equipment, techniques, and procedures. System

Under the FedRAMP Moderate baseline, MP-1 (MP-1 Policy and Procedures): FedRAMP Moderate Baseline · MP-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] media protection policy that: 2. Procedures to facilitate the implementation of the media protection policy and the associated media protection controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the media protection policy and procedure

NIST SP 800-171 Rev 3 control 03.08.07 (03.08.07 Media Use) is assessed by examining the following: Assessment Objectives: - the use of the following types of system media is restricted or prohibited: [organization-defined parameter]. - the use of removable system media without an identifiable owner is prohibited.

and b. Employ sanitization mechanisms with the strength and integrity commensurate with the security category or classification of the information. Discussion: Media sanitization applies to all digital and non-digital system media subject to disposal or reuse, whether or not the media is considered removable. Examples include digital media in scanners, copiers, printers, notebook computers, workstations, network components, mobile devices, and non-digital media (e.g., paper and microfilm). The sanitization process removes information from system media such that the information cannot be retrieved or reconstructed. Sanitization techniques including clearing, purging, cryptographic erase, de-identification of personally identifiable information, and destruction prevent the disclosure of information to unauthorized individuals when such media is reused or released for disposal. Organizations determine the appropriate sanitization methods, recognizing that destruction is sometimes necessary when other methods cannot be applied to media requiring sanitization. CHAPTER THREE PAGE 174 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53rev5>. NIST SP 800-53, REV.

NIST SP 800-171 Rev 3 control 03.08.03 (03.08.03 Media Sanitization) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Media Protection (MP) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-171 Rev 3 control 03.08.01 (03.08.01 Media Storage) falls under the Media Protection family. 03.08.01 · Media Storage Supplemental Guidance: System media include digital and non-digital media. Digital media include diskettes, flash drives, magnetic tapes, external or removable solid state or magnetic drives, compact discs, and digital versatile discs. Non-digital media include paper and microfilm. Physically controlling stored media includes conducting inventories, establishing procedures to allow individuals to check out and return media to libraries, and maintaining accountability for Supplemental Guidance: System media include digital and non-digital media. Digital media include diskettes, flash drives, magnetic tapes, external or removable solid state or magnetic drives, compact discs, and digital versatile discs. Non-digital media include paper and microfilm. Physically controlling stored media includes conducting inventories, establishing procedures to allow individuals to check out and return media to libraries, and maintaining accountability for stored media. Secure sto

Under the FedRAMP High baseline, MP-7 (MP-7 Media Use): FedRAMP High Baseline · MP-7 · Media Use Control Statement: a. [organization-defined parameter] the use of [organization-defined parameter] on [organization-defined parameter] using [organization-defined parameter] ; and b. Prohibit the use of portable storage devices in organizational systems when such devices have no identifiable owner. Supplemental Guidance: a. [organization-defined parameter] the use of [organization-defined parameter] on [organization-defined parameter] using [organizat

NIST SP 800-171 Rev 3 control 03.08.01 (03.08.01 Media Storage) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Media Protection (MP) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

MP-8 · Media Downgrading Control Statement: a. Establish [organization-defined parameter] that

includes employing downgrading mechanisms with strength and integrity commensurate with the security category or classification of the information; b. Verify that the system media downgrading process is commensurate with the security category and/or classification level of the information to be removed and the access authorizations of the potential recipients of the downgraded information; c. Identify [organization-defined parameter] ; and d. Downgrade the identified system media using the established process. Supplemental Guidance: a. Establish [organization-defined parameter] that includes employing downgrading mechanisms with strength and integrity commensurate with the security category or classification of the information; b. Verify that the system media downgrading process is commensurate with the security category and/or classification level of the information to be removed and the access authorizations of the potential recipients of the downgraded information; c. Identify [organization-defined parameter] ; and d. Downgrade the identified system media using the established process. Media downgrading applies to digital and non-digital media subject to release outside of the organization, whether the media is considered removable or not. When applied to system media, the downgrading process removes information from the media, typically by security category or classification level, such that the information cannot be retrieved or reconstructed. Downgrading of media includes redacting information to enable wider release and distribution. Downgrading ensures that empty space on the media is devoid of information.

Under the FedRAMP High baseline, MP-6.2 (MP-6.2 Equipment Testing): FedRAMP High Baseline · MP-6.2 · Equipment Testing Control Statement: Test sanitization equipment and procedures [organization-defined parameter] to ensure that the intended sanitization is being achieved. Supplemental Guidance: Test sanitization equipment and procedures [organization-defined parameter] to ensure that the intended sanitization is being achieved. Testing of sanitization equipment and procedures may be conducted by qualified and authorized external entities, including federal ag

NIST SP 800-171 Rev 3 control 03.08.07 (03.08.07 Media Use) falls under the Media Protection family. Control Statement: SR-03.08.07.a Restrict or prohibit the use of [organization-defined parameter]. SR-03.08.07.b Prohibit the use of removable system media without an identifiable owner. Supplemental Guidance: In contrast to requirement [(#/cprt/framework/version/SP_800_171_3_0_0/home?element=03.08.01)03.08.01, which restricts user access to media, this requirement restricts or prohibits the use of certain types of media, such as external hard drives, flash drives, or smart displays. Organizations can use technical and non-technical measures (e.g., policies, procedures, and rules of behavior) to control the use of system media. For example, organizations may control the use of

NIST SP 800-53 Rev 5 control MP-6.2 (Equipment Testing) is defined as follows: MP-6.2 · Equipment Testing Control Statement: Test sanitization equipment and procedures [organization-defined parameter] to ensure that the intended sanitization is being achieved. Supplemental Guidance: Test sanitization equipment and procedures [organization-defined parameter] to ensure that the intended sanitization is being achieved. Testing of sanitization equipment and procedures may be conducted by qualified and authorized external entities, including federal agencies or external service providers.

NIST SP 800-171 Rev 3 control 03.08.09 (03.08.09 System Backup · Cryptographic Protection) falls under the Media Protection family. Control Statement: SR-03.08.09.a Protect the confidentiality of backup information. SR-03.08.09.b Implement cryptographic mechanisms to prevent the unauthorized disclosure of CUI at backup storage locations. Supplemental Guidance: The selection of cryptographic mechanisms is based on the need to protect the confidentiality of backup information. Hardware security module (HSM) devices safeguard and manage cryptographic keys and provide cryptographic processing. Cryptographic operations (e.g., encryption, decryption, and signature generation and verification) are typically hosted on the HSM device, and many implementations provide hardware-accelerated mechanisms for cryptographic operations. This requ

NIST SP 800-171 Rev 3 control 03.08.04 (03.08.04 Media Marking) requires organizations to implement the following: 03.08.04 · Media Marking Supplemental Guidance: System media include digital and non-digital media. Marking refers to the use or application of human-readable security attributes. Labeling refers to the use of security attributes for internal system data structures. Digital media include diskettes, magnetic tapes, external or removable solid state or magnetic drives, flash drives, compact discs, and digital versatile discs. Non-digital media include paper and microfilm. CUI is defined by NARA a For practical implementation, organizations should document their approach

in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.08.04.

NIST SP 800-171 Rev 3 control 03.08.04 (03.08.04 Media Marking) is assessed by examining the following: Assessment Objectives: - system media that contain CUI are marked to indicate distribution limitations. - system media that contain CUI are marked to indicate handling caveats. - system media that contain CUI are marked to indicate applicable CUI markings.

NIST SP 800-53 Rev 5 control MP-1 (Policy and Procedures) is assessed by examining, interviewing, and testing: MP-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] media protection policy that: 2. Procedures to facilitate the implementation of the media protection policy and the associated media protection controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the media protection policy and procedures; and c. Review and update t

Implementing 03.08.05 (03.08.05 Media Transport) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.08.05 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.08.05 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

Under the FedRAMP Moderate baseline, MP-7 (MP-7 Media Use): FedRAMP Moderate Baseline · MP-7 · Media Use Control Statement: a. [organization-defined parameter] the use of [organization-defined parameter] on [organization-defined parameter] using [organization-defined parameter] ; and b. Prohibit the use of portable storage devices in organizational systems when such devices have no identifiable owner. Supplemental Guidance: a. [organization-defined parameter] the use of [organization-defined parameter] on [organization-defined parameter] using [organ

NIST SP 800-171 Rev 3 control 03.08.05 (03.08.05 Media Transport) is assessed by examining the following: Assessment Objectives: - system media that contain CUI are protected during transport outside of controlled areas. - system media that contain CUI are controlled during transport outside of controlled areas. - activities associated with the transport of system media that contain CUI are documented. - accountability for system media that contain CUI is maintained during transport outside of controlled areas.

NIST SP 800-53 Rev 5 control MP-6.7 (Dual Authorization): MP-6.7 · Dual Authorization Control Statement: Enforce dual authorization for the sanitization of [organization-defined parameter]. Supplemental Guidance: Enforce dual authorization for the sanitization of [organization-defined parameter]. Organizations employ dual authorization to help ensure that system media sanitization cannot occur unless two technically qualified individuals conduct the de

Implementing 03.08.02 (03.08.02 Media Access) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.08.02 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.08.02 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly

defined regardless of environment.

Under the FedRAMP High baseline, MP-6 (MP-6 Media Sanitization): FedRAMP High Baseline · MP-6 · Media Sanitization Control Statement: a. Sanitize [organization-defined parameter] prior to disposal, release out of organizational control, or release for reuse using [organization-defined parameter] ; and b. Employ sanitization mechanisms with the strength and integrity commensurate with the security category or classification of the information. Supplemental Guidance: a. Sanitize [organization-defined parameter] prior to disposal, release out of organizational

NIST SP 800-171 Rev 3 control 03.08.03 (03.08.03 Media Sanitization) requires organizations to implement the following: 03.08.03 · Media Sanitization Supplemental Guidance: Media sanitization applies to digital and non-digital media that are subject to disposal or reuse, whether or not the media are considered removable. Examples include digital media in scanners, copiers, printers, notebook computers, mobile devices, workstations, network components, and non-digital media. The sanitization process removes CUI from media such that the information cannot be retrieved or reconstructed. Sanitization techniques (e.g. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.08.03.

NIST SP 800-171 Rev 3 control 03.08.09 (03.08.09 System Backup · Cryptographic Protection) is assessed by examining the following: Assessment Objectives: - cryptographic mechanisms are implemented to prevent the unauthorized disclosure of CUI at backup storage locations. - the confidentiality of backup information is protected.

NIST SP 800-53 Rev 5 control MP-7 (Media Use) is assessed by examining, interviewing, and testing: MP-7 · Media Use Control Statement: a. [organization-defined parameter] the use of [organization-defined parameter] on [organization-defined parameter] using [organization-defined parameter] ; and b. Prohibit the use of portable storage devices in organizational systems when such devices have no identifiable owner. Supplemental Guidance: a. [organization-defined parameter] the use of [organization-defined parameter] on [organization-defined parameter] using [organization-defined parameter] ; a

NIST SP 800-53 Rev 5 control MP-6 (Media Sanitization) is assessed by examining, interviewing, and testing: MP-6 · Media Sanitization Control Statement: a. Sanitize [organization-defined parameter] prior to disposal, release out of organizational control, or release for reuse using [organization-defined parameter] ; and b. Employ sanitization mechanisms with the strength and integrity commensurate with the security category or classification of the information. Supplemental Guidance: a. Sanitize [organization-defined parameter] prior to disposal, release out of organizational control, or release for

Under the FedRAMP High baseline, MP-6.3 (MP-6.3 Nondestructive Techniques): FedRAMP High Baseline · MP-6.3 · Nondestructive Techniques Control Statement: Apply nondestructive sanitization techniques to portable storage devices prior to connecting such devices to the system under the following circumstances: [organization-defined parameter]. Supplemental Guidance: Apply nondestructive sanitization techniques to portable storage devices prior to connecting such devices to the system under the following circumstances: [organization-defined parameter]. Portable storage de

NIST SP 800-53 Rev 5 control MP-4.2 (Automated Restricted Access) is assessed by examining, interviewing, and testing: MP-4.2 · Automated Restricted Access Control Statement: Restrict access to media storage areas and log access attempts and access granted using [organization-defined parameter]. Supplemental Guidance: Restrict access to media storage areas and log access attempts and access granted using [organization-defined parameter]. Automated mechanisms include keypads, biometric readers, or card readers on the external entries to media storage areas.

Under the FedRAMP High baseline, MP-3 (MP-3 Media Marking): FedRAMP High Baseline · MP-3 · Media Marking Control Statement: a. Mark system media indicating the distribution limitations, handling caveats, and applicable security markings (if any) of the information; and b. Exempt [organization-defined parameter] from marking if the media remain within [organization-defined parameter]. Supplemental Guidance: a. Mark system media indicating the distribution limitations, handling caveats, and applicable security markings (if any) of the information; and b.

NIST SP 800-53 Rev 5 control MP-7 (Media Use): MP-7 · Media Use Control Statement: a. [organization-defined parameter] the use of [organization-defined parameter] on [organization-defined parameter] using [organization-defined parameter] ; and b. Prohibit the use of portable storage devices in organizational systems when such devices have no identifiable owner. Supplemental Guidance: a. [organization-defined parameter] the use of [organization-defined parameter]

NIST SP 800-53 Rev 5 control MP-8.3 (Controlled Unclassified Information) is defined as follows: MP-8.3 · Controlled Unclassified Information Control Statement: Downgrade system media containing controlled unclassified information prior to public release. Supplemental Guidance: Downgrade system media containing controlled unclassified information prior to public release. The downgrading of controlled unclassified information uses approved sanitization tools, techniques, and procedures.

NIST SP 800-171 Rev 3 control 03.08.02 (03.08.02 Media Access) is assessed by examining the following: Assessment Objectives: - access to CUI on system media is restricted to authorized personnel or roles.

NIST SP 800-171 Rev 3 control 03.08.04 (03.08.04 Media Marking) requires organizations to implement the following: 03.08.04 · Media Marking Supplemental Guidance: System media include digital and non-digital media. Marking refers to the use or application of human-readable security attributes. Labeling refers to the use of security attributes for internal system data structures. Digital media include diskettes, magnetic tapes, external or removable solid state or magnetic drives, flash drives, compact discs, and digital versatile discs. Non-digital media include paper and microfilm. CUI is defined by NARA a For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.08.04.

NIST SP 800-53 Rev 5 control MP-7.2 (Prohibit Use of Sanitization-resistant Media) is assessed by examining, interviewing, and testing: MP-7.2 · Prohibit Use of Sanitization-resistant Media Control Statement: Prohibit the use of sanitization-resistant media in organizational systems. Supplemental Guidance: Prohibit the use of sanitization-resistant media in organizational systems. Sanitization resistance refers to how resistant media are to non-destructive sanitization techniques with respect to the capability to purge information from media. Certain types of media do not support sanitization commands, or if supported, the int

NIST SP 800-53 Rev 5 control MP-5 (Media Transport) is assessed by examining, interviewing, and testing: MP-5 · Media Transport Control Statement: a. Protect and control [organization-defined parameter] during transport outside of controlled areas using [organization-defined parameter]; b. Maintain accountability for system media during transport outside of controlled areas; c. Document activities associated with the transport of system media; and d. Restrict the activities associated with the transport of system media to authorized personnel. Supplemental Guidance: a. Protect and control [organization-defined parameter]

NIST SP 800-171 Rev 3 control 03.08.05 (03.08.05 Media Transport) is assessed by examining the following: Assessment Objectives: - system media that contain CUI are protected during transport outside of controlled areas. - system media that contain CUI are controlled during transport outside of controlled areas. - activities associated with the transport of system media that contain CUI are documented. - accountability for system media that contain CUI is maintained during transport outside of controlled areas.

Implementing 03.08.09 (03.08.09 System Backup · Cryptographic Protection) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.08.09 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.08.09 are implemented by the CSP (with reference to the

CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-171 Rev 3 control 03.08.07 (03.08.07 Media Use) requires organizations to implement the following: Control Statement: SR-03.08.07.a Restrict or prohibit the use of [organization-defined parameter]. SR-03.08.07.b Prohibit the use of removable system media without an identifiable owner. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.08.07.

NIST SP 800-171 Rev 3 control 03.08.04 (03.08.04 Media Marking) is assessed by examining the following: Assessment Objectives: - system media that contain CUI are marked to indicate distribution limitations. - system media that contain CUI are marked to indicate handling caveats. - system media that contain CUI are marked to indicate applicable CUI markings.

NIST SP 800-53 Rev 5 control MP-8.3 (Controlled Unclassified Information): MP-8.3 · Controlled Unclassified Information Control Statement: Downgrade system media containing controlled unclassified information prior to public release. Supplemental Guidance: Downgrade system media containing controlled unclassified information prior to public release. The downgrading of controlled unclassified information uses approved sanitization tools, techniques, and procedures.

NIST SP 800-53 Rev 5 control MP-8 (Media Downgrading) is assessed by examining, interviewing, and testing: MP-8 · Media Downgrading Control Statement: a. Establish [organization-defined parameter] that includes employing downgrading mechanisms with strength and integrity commensurate with the security category or classification of the information; b. Verify that the system media downgrading process is commensurate with the security category and/or classification level of the information to be removed and the access authorizations of the potential recipients of the downgraded information; c. Identify

NIST SP 800-171 Rev 3 control 03.08.02 (03.08.02 Media Access) is assessed by examining the following: Assessment Objectives: - access to CUI on system media is restricted to authorized personnel or roles.

NIST SP 800-171 Rev 3 control 03.08.01 (03.08.01 Media Storage) is assessed by examining the following: Assessment Objectives: - system media that contain CUI are physically controlled. - system media that contain CUI are securely stored.

Under the FedRAMP Low baseline, MP-1 (MP-1 Policy and Procedures): FedRAMP Low Baseline · MP-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] media protection policy that: 2. Procedures to facilitate the implementation of the media protection policy and the associated media protection controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the media protection policy and procedures; an